

Roles, Pages & Access

دليل الأدوار والصلاحيات — AIGP Transformation Portal

For the IT team — who each role is, the pages they see, the actions they can take, the workflow gates, and the exact server-enforced permission matrix.

Maintained in git at docs/roles-pages-access.md · 13 July 2026

A plain-language reference for IT: **who each role is, which pages they see, what they can do, and what the server lets them touch.** The authoritative sources in code are `prisma/seed.ts` (permission matrix), `lib/security/rbac.ts` (enforcement) and `lib/viewModel.ts` (page/menu scoping).

1. How access works (two layers)

- **UI role** (`users.role` , one of `coord / entity / path / ai / admin`) — decides which **screens, menus, cards and buttons** the user sees.
- **Backend RBAC** (`user_roles` → `role_permissions` + entity/stream scopes) — every API call re-checks: valid session → permission code → entity/stream scope → action, and writes an `audit_logs` row. Hiding a button is UX only; the server check is what actually protects the data.

On first login the identity (UAE PASS / Workspace ONE / mock-dev) is mapped to a `users` row; the UI role and backend role are assigned from `role_assignment_rules` , team setup, or the admin APIs.

2. Quick reference

UI role	Arabic	Backend code	Data scope	One-line job
coord	منسق المسار في الجهة	entity_coordinator	own entity + own stream (incl. drafts)	Creates and submits the entity's entries for one stream
entity	ممثل الجهة	entity_representative	own entity, all streams (no drafts)	The sole approver of the entity's entries (ent1 gate)
path	رئيس المسار	stream_owner	own stream, all entities (approved items only)	Oversees the stream nationally and nominates for funding
ai	اللجنة الوطنية	ai_committee	everything (approved items + nominations)	Reviews nominations and approves funding from the committee wallet
admin	مشرف النظام	system_admin	global	Manages users, roles, assignments and audit logs

Streams: بناء (services) · الخدمات (strategy) · العمل الحكومي الاستراتيجي (ops) · العمليات والدعم المؤسسي (tech) · تقنيات الذكاء الاصطناعي والبيانات (capacity) · القدرات والتدريب.

Types per stream (enforced everywhere — menus, filters, KPIs, creation): only in عملية · in all streams مشروع/مبادرة: ops + strategy · only in خدمة.

3. Role by role

3.1 منسق المسار في الجهة — coord / entity_coordinator

Who: the working-level user inside a federal entity, responsible for one stream — or several: when the account carries more than one row in `user_stream_scopes`, the header shows a **stream switcher** and the whole workspace (lists, dashboards, wizard) re-scopes to the selected stream. Appointed by their entity representative in team setup.

Pages (sidebar):

- الرئيسية — stream dashboard (cost + inputs summaries, type cards)
- جميع الأنواع — the entry list, with sub-items only for the types the stream actually has (المشاريع والمبادرات، العمليات، الخدمات and/or الخدمات)
- مراحل التنفيذ — execution stages with «تخطيط المرحلة» (assign entries)
- خطة الإطلاق — scheduled launches + «إدارة الإطلاق» (create/edit launches)
- دليل الاستخدام

All entry lists carry a **stages filter (المراحل)** — the four stages plus «للتحديد بعد الدراسة»; the wizard can defer the stage decision with that same option, which shows as an amber chip on the card until a stage is assigned. Lists are ordered by stage (المرحلة الأولى first; unassigned/TBD last).

Can do: create entries (زر «إضافة مدخل جديد» + bulk upload), edit drafts, resubmit returned entries, submit for approval, plan stages and launches, update execution checklists, export reports.

Cannot: approve or reject anything; see other entities or other streams; see the funding basket. Drafts are visible **only** to the coordinator.

3.2 ممثل الجهة — entity / entity_representative

Who: the entity's official approver — one per entity, across all streams.

Pages (sidebar):

- الرئيسية — entity dashboard (cost + inputs summaries, distribution by stream)
- جميع المسارات — drill-down by stream; entry list with filters (streams, types, statuses, funding state, search)
- مراحل التنفيذ / خطة الإطلاق — with a **streams filter**; launches show a «... مسار» chip on every launch and entry
- فريق العمل — registers the entity team (assigns its coordinators)
- دليل الاستخدام

Can do: **إضافة / رفض / طلب تفاصيل إضافية** on submitted entries (the ent1 gate — the only role with this power), register the team, see all costs, export reports. Approve/reject permissions are granted server-side (`items:approve`, `items:reject`).

Cannot: see coordinator drafts; see other entities; nominate or fund.

3.3 رئيس المسار — path / stream_owner

Who: the national head of ONE stream, seeing that stream across **all** entities. Assigned by the system admin.

Pages (sidebar):

- الرئيسية — stream dashboard (type cards for the stream's own types only)
- جميع الأنواع — entity-approved entries of the stream, with an **entities filter** (no streams filter — the stream is fixed)

- **مراحل التنفيذ / خطة الإطلاق** — with the entities filter; launches show the **entity chip** on every launch and entry; budgets hidden, status pills shown
- **الجهات** — one card per participating entity: entries broken down **by type** within his stream, plus «المدخلات» and «المدخلات المعتمدة للتمويل» with the approved cost
- **سلة التمويل** — the nomination basket
- **دليل الاستخدام**

Can do: **ترشيح للتمويل** (nominate approved entries to the committee), withdraw nominations, approve launch plans, export.

Cannot: see drafts or items awaiting entity approval; see other streams; approve funding; see money on the launch plan.

3.4 اللجنة الوطنية — `ai` / `ai_committee`

Who: the national committee controlling the approved budget (the wallet, default 100M AED).

Pages (sidebar):

- **الرئيسية** — national dashboard (توزيع المدخلات حسب المسار, committee stats)
- **المدخلات المرشحة للتمويل** — the review list
- **قائمة الاعتماد والتمويل** — the funding basket with the wallet (approved/remaining budget)
- **مراحل التنفيذ / خطة الإطلاق** — with **both** entities and streams filters; launches show **entity + stream chips**
- **دليل الاستخدام**

Can do: **رفض التمويل / اعتماد التمويل** (with mandatory cancellation reason when withdrawing funding), adjust program-phase deadlines, run the AI reviewer, export.

Cannot: create or edit entries; act on items that were never nominated (the committee acts on `nominations`, not raw items).

3.5 مشرف النظام — `admin` / `system_admin`

Who: IT / platform administration. Bypasses permission checks server-side; every action is still audit-logged.

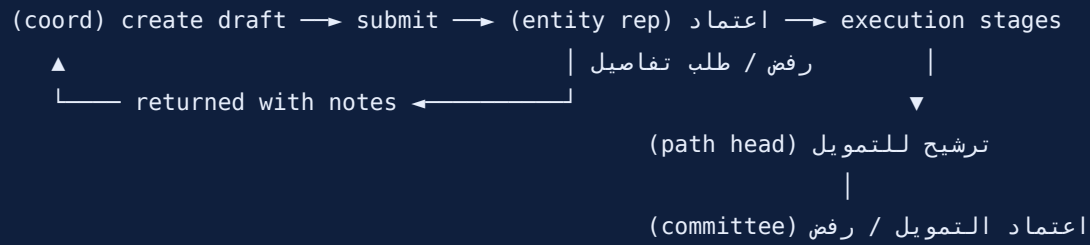
Pages: the admin console instead of the dashboards — plus a «لوحات المتابعة» button that opens **all monitoring dashboards with the committee-wide scope** (a «لوحة الإدارة» button returns to the console) —

- **المستخدمون** — create/edit/enable/disable users, bulk upload from the Excel template
- **رؤساء المسارات واللجنة** — assign the five stream heads and the committee
- **الأدوار والصلاحيات** — role reference

In production the full management surface is the **admin API suite** (`/api/admin/users|roles|role-rules|entities|streams|audit-logs`), plus `BOOTSTRAP_ADMIN_EMAILS` for the very first sign-in.

Division of provisioning: the admin assigns stream heads + committee; each entity representative provisions their own coordinators via **فريق العمل**.

4. The workflow and who acts at each step



- Drafts (`wf = draft`): visible to the coordinator only.
- Awaiting approval (`ent1`): coordinator + entity representative.
- Approved onwards (`exec / launch / done`): also stream head and committee.
- Every server-side action lands in `log_entries` (business trail shown in السجل) and `audit_logs` (security trail with actor/IP/user-agent).

5. Backend permission matrix (seeded — `prisma/seed.ts`)

Permission	coord	entity rep	stream head	committee	admin
items:view / export	✓	✓	✓	✓	✓
items:create / update / submit	✓	✓	—	—	✓
items:approve / reject	—	✓	✓ ¹	✓ ¹	✓
launch_plans:view	✓	✓	✓	✓	✓
launch_plans:approve	—	—	✓	—	✓
nominations:view	✓	✓	✓	✓	✓
nominations:approve / reject	—	—	✓	—	✓
funding:view	✓	✓	✓	✓	✓
funding:approve / reject / cancel	—	—	—	✓	✓
reports:view	✓	✓	✓	✓	✓
reports:export	—	✓	—	✓	✓
ai_review:run	—	—	—	✓	✓
users / roles / audit / settings	—	—	—	—	✓

¹ The permission exists for gates inside their own scope; in the UI flow the ent1 approval is performed by the entity representative.

Extra backend-only roles (no dedicated UI — they land on the closest read-only view):

- `program_admin` (مدير البرنامج): everything except `settings:*`.
- `entity_admin` (مسؤول الجهة): entity rep minus approve/reject, plus `entities:update`.
- `viewer` (مستعرض): read-only within assigned scopes.
- `auditor` (مدقق): read-only + `audit:view` + exports.

6. Where this is enforced in code

Concern	File
Permission + scope checks per request	<code>lib/security/rbac.ts</code> (<code>assertPermission</code> , <code>assertItemAccess</code>)
Session → user + roles + scopes	<code>lib/security/auth.ts</code> , <code>/api/auth/me</code>
Role/permission/scope tables	<code>prisma/schema.prisma</code> (migration <code>0009</code>)
Seeded matrix + starter accounts	<code>prisma/seed.ts</code>
Page/menu/filter scoping (UX)	<code>lib/viewModel.ts</code>
Identity → user mapping on login	<code>lib/security/user-access.ts</code>